

AI SAFETY UAE · SATURDAY, AUGUST 22, 2026 · 11:00 GST · ONLINE

Regulated AI Agents

with DORA and NIS2

What breaks when an agent touches money, and the engineering primitive nobody shipped

Amin Hasbini · AI & Cybersecurity Executive · 12 years directing global threat research (META, 70 countries)

WHO IS SPEAKING

Amin Hasbini

AI & Cybersecurity Executive

BUILD

AI for security

Built the machine-learning system that generates half of Kaspersky's threat intelligence. PhD in Information Security, Brunel University London.

TRANSLATE

Institutions and the public

Expert witness to the French Senate (OPECST) on AI. Worked with three Interpol Secretary-Generals. CNN, BBC, Forbes, Al Jazeera, Sky News Arabia.

OPERATE

Twelve years in the field

Directed Kaspersky's GReAT research for the Middle East, Türkiye and Africa, to 2025. State-sponsored investigations, security programmes with more than ten central banks.

THIS TALK COMES FROM

Two open-access paper series, DOI-anchored · AI agent security, and post-quantum cryptography for agents · today's material is Paper II.3, The Evidence Question · comments filed on prEN 18282, the European standard behind the AI Act's cybersecurity presumption · post-quantum and crypto-agility roadmap lead, European Champions Alliance cyber group

Everything today is checkable: public documents, open papers, a live demo.

YOUR AGENT WORKS. THEN SOMETHING GOES WRONG.

Four ordinary questions

- 1 Which agent did this?
- 2 What exactly did it do?
- 3 Who gave it the authority to do that?
- 4 **Can you show me a record of all of this that nobody in this company could have edited afterwards?**

For a human employee, thirty years of enterprise IT answers these. **For your agent, today, the honest answer to question four is no.**

Logs are not evidence

TELEMETRY

- **What you collect to debug your system**
- Keyed by names a developer chose
- Editable, deletable, redirectable by the operator
- Answers: what probably happened

EVIDENCE

- **A record that survives its own operator**
- Attributable: this agent, this action, this authority
- Tamper-evident: editing it breaks verification
- Answers: what happened, provably, to an outsider

Agents produce telemetry. Almost nobody's agents produce evidence.

The platforms are racing to the agent layer. The evidence property is not arriving.

OPENAI

Agent identifiers, activity views, a compliance stream described as immutable on one surface. On another, individual agent actions are excluded from compliance logs. SDK tracing is client-side observability the operator controls.

ANTHROPIC

Per-instance sessions with tool-call event streams, end-user vaults. Every endpoint authenticates with the organisation's workspace key. Sessions and their records are operator-deletable. Nothing described as signed.

MISTRAL

First-class agent identifiers, naming a configuration rather than a running instance. Per-event observability exports into editable datasets. The organisation audit log covers admin events, without export.

THE PATTERN, ACROSS ALL THREE

Identity authenticates at the organisation and its credentials, one level above the actor. No reviewed surface documents an independently verifiable record binding agent + action + authority. **The org can prove who holds the key. It cannot prove which agent did what, on whose delegated authority.**

The evidence property list

IDENTITY

A stable identifier for the agent and for the running instance, not just the configuration

AUTHORITY

The initiating principal, human or service, and the scope it delegated

ACTIONS

The consequential actions and their results, complete

TIME

Trusted time, not the operator's clock

INTEGRITY

Protection that survives the operator: if you can edit it, it is not evidence

RETENTION

Aligned to how long someone might ask, not to your debug window

EXPORT

The record leaves the platform without losing its provenance

Signatures, hash chains, timestamps, workload identity, immutable pipelines: the toolchain exists.

What is missing is the assembly, at the agent layer, as a default. Today, you build it.

NOW THE REGULATIONS IN THE TITLE

Everything above is already the law

DORA

APPLYING SINCE 17 JANUARY 2025

Never says the word agent. Technology-neutral: your agent is software in the entity's systems, an ICT asset, and the existing duties absorb it the day it goes live. Inventory it, limit and authenticate it, detect it, and produce the record.

ECB

BANK ACTION PLANS DUE 31 OCTOBER 2026

In July, the ECB's supervisory board chair wrote to every significant bank CEO: concrete plan, roles, resources, timelines. Same letter: post-quantum adoption must start now. A dedicated quantum letter is announced.

AI ACT

THE SLOW EDGE: END 2027 AND 2028

The law with AI in its name treats agents as no separate category, and its high-risk logging duties are deferred. The regulation that reaches your agent first is the one that never says AI.

Not in the EU? Your enterprise customers are regulated and their duties flow into your product · the regional rails move the same direction · and any serious buyer of agents is about to ask these exact questions.

Plan against the clock that is running, not the one that just slipped.

A receipt is a signature. Signatures age.

The record's integrity comes from cryptography. **Where a signature is what makes agent evidence authentic and attributable, the signature's continued validity is a load-bearing dependency of that evidence.** If it is a fixed classical scheme inherited from a framework default, the evidence someone reads in five years is being written today on cryptography with a published deprecation horizon.

US EXECUTIVE ORDER · JUNE 2026

- Post-quantum key establishment: end of 2030
- **Post-quantum digital signatures: end of 2031**
- The split is the message: signatures are their own migration, with their own clock. Agent identity and receipts live in the signature half.

EU FINANCIAL REGULATION, ALREADY BINDING

- The DORA technical standard requires the capability to update cryptography as cryptanalysis develops
- **Agility, not a one-time move**
- Design rule for builders: no hard-coded signature algorithms in anything meant to be read years later. Make it swappable.

That one design decision is the difference between a receipt layer and a liability.

Five things to do Monday

- 1 Inventory** Put your agents in the asset inventory, as assets, with the cryptography they carry. No inventory line, no key.
- 2 Access** Map each agent to the access model you already run for humans: what may it touch, how limited, whose authority.
- 3 Evidence or telemetry** Decide, per agent, honestly, which one it produces. Know the difference before someone asks.
- 4 Agility** Agent credentials and receipts go on the crypto-agility list. Swappable algorithms, no framework-frozen signatures.
- 5 The calendar** DORA now. NIS2 where transposed. AI Act later than the headlines. Plan against the running clock.

Build agents that can show their receipts.

Because the ones that cannot are about to become very hard to sell.

PAPERS · OPEN ACCESS, DOI-ANCHORED

mahasbini.org/papers

THIS TALK'S PAPER · THE EVIDENCE QUESTION

mahasbini.org/papers/s2-03-the-evidence-question

LIVE RECEIPTS DEMO · TRY THE TAMPER BUTTON

trustlab.mahasbini.org

AGENT CRYPTO INVENTORY · CBOM

agentcbom.mahasbini.org

Amin Hasbini · mahasbini.org · Paris, regularly in the Gulf